

VULNERABILITY ASSESSMENT REPORT

Metasploitable 2 — Penetration Test

Hands-on VAPT Lab Exercise

Assessor	Mithun	Report Date	June 16, 2026
Target	Metasploitable 2	Target IP	192.168.56.101
Attacker IP	192.168.56.102 (Kali)	Methodology	Black Box
Classification	CONFIDENTIAL	Overall Risk	CRITICAL

1. Executive Summary

A comprehensive vulnerability assessment was conducted against a Metasploitable 2 target system simulating a real-world enterprise environment. The assessment identified **six critical and high-severity vulnerabilities** spanning network services, web applications, and privilege escalation paths. All identified vulnerabilities allowed full system compromise, including unauthenticated remote code execution and root-level access. Immediate remediation through patching and hardening is strongly recommended.

This assessment was conducted in a controlled lab environment as part of a structured VAPT learning exercise. All techniques used are mapped to the MITRE ATT&CK; framework and reflect real-world attack methodologies used by threat actors against enterprise systems.



2. Scope and Methodology

Target System	Metasploitable 2
Target IP Address	192.168.56.101
Attacker Machine	Kali Linux — 192.168.56.102
Assessment Type	Black Box Penetration Test
Assessment Date	June 16, 2026
Tools Used	Nmap, Nikto, Gobuster, Metasploit Framework, Netcat, Enum4linux
Methodology	Reconnaissance → Enumeration → Exploitation → Post-Exploitation → Reporting

3. Reconnaissance Findings

An Nmap full-port scan was conducted to enumerate all open services on the target. The following services were identified:

Port	State	Service	Version	Risk
21/tcp	Open	FTP	vsftpd 2.3.4	Critical
22/tcp	Open	SSH	OpenSSH 4.7p1	Low
23/tcp	Open	Telnet	Linux telnetd	High
25/tcp	Open	SMTP	Postfix smtpd	Medium
80/tcp	Open	HTTP	Apache 2.2.8	High
139/tcp	Open	NetBIOS	Samba 3.x	Critical
445/tcp	Open	SMB	Samba 3.x	Critical

3306/tcp	Open	MySQL	MySQL 5.0	Critical
3632/tcp	Open	distccd	distccd v1	High
5432/tcp	Open	PostgreSQL	PostgreSQL 8.3	High
6667/tcp	Open	IRC	UnrealIRCd 3.2.8.1	Critical
8180/tcp	Open	HTTP-Alt	Apache Tomcat 5.5	High

4. Findings Summary

#	Vulnerability	Port	Severity	CVSS	CVE
F-01	vsftpd 2.3.4 Backdoor — RCE	21/tcp	Critical	10.0	CVE-2011-2523
F-02	Samba Usermap Script — RCE	139/tcp	Critical	10.0	CVE-2007-2447
F-03	MySQL Unauthenticated Access	3306/tcp	Critical	9.8	—
F-04	UnrealIRCd Backdoor — RCE	6667/tcp	Critical	10.0	CVE-2010-2075
F-05	distccd RCE + SUID Privesc	3632/tcp	High	9.0	CVE-2004-2687
F-06	DVWA SQLi, XSS, File Upload RCE	80/tcp	High	8.8	—

5. Detailed Findings

F-01 — vsftpd 2.3.4 Backdoor — Remote Code Execution			CRITICAL
CVSS Score	10.0	CVE	CVE-2011-2523
Port / Service	21/tcp (FTP)	MITRE ATT&CK	T1190 — Exploit Public-Facing Application

Description

The target runs vsftpd version 2.3.4, which contains a malicious backdoor introduced into the source code. When a username containing a smiley face ':' is submitted during authentication, the backdoor opens a shell listener on TCP port 6200, granting unauthenticated root access.

Steps to Reproduce

1. Nmap scan identified vsftpd 2.3.4 on port 21
2. Searchsploit confirmed backdoor exploit availability
3. Metasploit module exploit/unix/ftp/vsftpd_234_backdoor executed
4. Root shell obtained without any valid credentials

Remediation

Upgrade vsftpd to the latest stable version immediately. Replace FTP with SFTP where possible. Restrict FTP access via firewall rules to trusted IPs only.

F-02 — Samba Usermap Script — Remote Code Execution			CRITICAL
CVSS Score	10.0	CVE	CVE-2007-2447
Port / Service	139/tcp, 445/tcp (SMB)	MITRE ATT&CK	T1210 — Exploitation of Remote Services

Description

The Samba service running on the target is vulnerable to a command injection flaw in the username map script configuration option. An unauthenticated attacker can pass shell metacharacters in the username field to execute arbitrary commands as root.

Steps to Reproduce

1. Nmap and enum4linux identified Samba 3.x running on ports 139 and 445
2. Searchsploit confirmed CVE-2007-2447 applicability
3. Metasploit module exploit/multi/samba/usermap_script executed
4. Root shell obtained without authentication

Remediation

Update Samba to the latest version. Disable the 'username map script' option in smb.conf. Restrict SMB access to trusted networks via firewall.

F-03 — MySQL Unauthenticated Root Access			CRITICAL
CVSS Score	9.8	CVE	—
Port / Service	3306/tcp (MySQL)	MITRE ATT&CK	T1078 — Valid Accounts / Default Credentials

Description

The MySQL database service on the target accepts connections from the root account with no password. Any attacker with network access to port 3306 can connect and gain full administrative control over all databases, including reading, modifying, and deleting all stored data.

Steps to Reproduce

1. Nmap identified MySQL 5.0 running on port 3306
2. Connected using: `mysql -h 192.168.56.101 -u root` (no password)
3. Successfully executed 'show databases' and accessed all schemas
4. Extracted user credentials from the dwwa database

Remediation

Set a strong password for the MySQL root account immediately. Bind MySQL to localhost only (bind-address = 127.0.0.1). Remove anonymous user accounts and test databases.

F-04 — UnrealIRCd Backdoor — Remote Code Execution			CRITICAL
CVSS Score	10.0	CVE	CVE-2010-2075
Port / Service	6667/tcp (IRC)	MITRE ATT&CK	T1190 — Exploit Public-Facing Application

Description

UnrealIRCd version 3.2.8.1 running on the target contains a malicious backdoor inserted into the source code distribution. The backdoor executes arbitrary commands when a specially crafted string prefixed with 'AB;' is sent to the server, granting unauthenticated remote code execution as root.

Steps to Reproduce

1. Nmap service scan identified UnrealIRCd 3.2.8.1 on port 6667
2. Metasploit module `exploit/unix/irc/unreal_ircd_3281_backdoor` used
3. Root shell obtained with a single exploit execution

Remediation

Remove UnrealIRCd 3.2.8.1 immediately and replace with a verified clean version. If IRC is not required, disable and remove the service entirely. Block port 6667 at the firewall.

F-05 — distccd RCE with SUID Privilege Escalation			HIGH
CVSS Score	9.0	CVE	CVE-2004-2687

Port / Service	3632/tcp (distccd)	MITRE ATT&CK	T1190 / T1548.001 — RCE + SUID Exploitation
-----------------------	--------------------	-------------------------	---

Description

The distccd service (distributed C compiler daemon) running on port 3632 allows unauthenticated command execution. Initial access is obtained as the 'daemon' user. Further, the Nmap binary on the target has the SUID bit set, allowing privilege escalation to root via Nmap's interactive mode.

Steps to Reproduce

1. Nmap identified distccd running on port 3632
2. Metasploit module exploit/unix/misc/distcc_exec executed with cmd/unix/reverse payload
3. Shell obtained as 'daemon' user
4. SUID binary search: find / -perm -u=s -type f 2>/dev/null revealed /usr/bin/nmap
5. Executed: /usr/bin/nmap --interactive, then !sh to obtain root shell

Remediation

Disable distccd if not required. Remove the SUID bit from Nmap: chmod -s /usr/bin/nmap. Apply principle of least privilege to all running services.

F-06 — DVWA — SQL Injection, XSS, and File Upload RCE			HIGH
CVSS Score	8.8	CVE	—
Port / Service	80/tcp (HTTP)	MITRE ATT&CK	T1190 / T1059 — Web Application Exploitation

Description

The Damn Vulnerable Web Application (DVWA) hosted on the target's Apache web server contains multiple OWASP Top 10 vulnerabilities. SQL Injection allows complete database extraction, Reflected XSS allows session hijacking, and an unrestricted file upload vulnerability allows uploading a PHP web shell leading to remote code execution.

Steps to Reproduce

1. Gobuster and Nikto enumerated web directories including /dvwa, /phpMyAdmin, /mutillidae
2. DVWA SQL Injection: payload "' OR 1=1-- " used to bypass authentication and dump user table
3. DVWA XSS: alert('XSS') confirmed reflected cross-site scripting
4. File Upload: PHP reverse shell uploaded bypassing client-side validation; RCE obtained

Remediation

Use parameterized queries / prepared statements to prevent SQLi. Implement Content Security Policy (CSP) headers to mitigate XSS. Validate and restrict file uploads by type, size, and content. Deploy a Web Application Firewall (WAF).

6. MITRE ATT&CK; Mapping

Tactic	Technique	ID	Finding
Reconnaissance	Network Service Scanning	T1046	All
Initial Access	Exploit Public-Facing Application	T1190	F-01, F-02, F-04, F-05
Initial Access	Valid Accounts / Default Credentials	T1078	F-03
Execution	Command & Scripting Interpreter	T1059	F-06
Privilege Escalation	Abuse Elevation Control — SUID	T1548.001	F-05
Credential Access	Brute Force / Default Credentials	T1110	F-03
Collection	Data from Local System	T1005	F-03, F-06
Defense Evasion	Exploitation for Defense Evasion	T1211	F-05

7. Remediation Summary

Priority	Action	Finding
Immediate	Patch/remove vsftpd 2.3.4 — replace with SFTP	F-01
Immediate	Update Samba — disable username map script	F-02
Immediate	Set MySQL root password — bind to localhost only	F-03
Immediate	Remove UnrealIRCd 3.2.8.1 — install verified version	F-04
High	Disable distccd — remove SUID bit from Nmap	F-05
High	Implement WAF — use prepared statements — restrict file uploads	F-06
Ongoing	Apply OS and software patches regularly	All
Ongoing	Implement network segmentation and firewall rules	All
Ongoing	Conduct regular vulnerability assessments	All

8. Conclusion

The vulnerability assessment of Metasploitable 2 revealed a severely compromised security posture. All six identified vulnerabilities are exploitable by an attacker with basic network access, and four of them allow direct root-level code execution without any authentication. The attack surface spans multiple service categories including FTP, SMB, IRC, database, and web application layers.

The identified vulnerabilities are the result of outdated software versions, default credentials, misconfigured services, and insecure application development practices. All findings are well-documented CVEs with publicly available exploits, making them high-priority targets for real-world threat actors.

It is strongly recommended that all critical findings be remediated immediately, followed by a re-assessment to verify the effectiveness of applied fixes. A continuous vulnerability management program should be established to prevent recurrence.

OVERALL RISK RATING: CRITICAL

This report was generated as part of a controlled lab-based VAPT exercise. All testing was conducted in an isolated environment with no production systems affected. — Assessor: Mithun | June 16, 2026